

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Python Data Extraction Service

Sales POD Invoice Intelligence Platform

Official Project ID: Sales_POD_Invoice_Intelligence_Platform

Assessment Type: Internal VAPT / Application Security Assessment

NOT an independent third-party certification

Organization: Mediola / Globalspace (Internal Security Assessment)

Component: Python Data Extraction Service

Assessment Date: 2026-09-22

Report Version: 1.0

Classification: CONFIDENTIAL

Evidence-based findings only. Items that were not tested are marked Not Tested.

1. Confidentiality Notice

This document contains confidential security assessment information for the Sales POD Invoice Intelligence Platform. Distribution is restricted to authorized personnel of the organization. Do not publish externally. Secrets and customer invoice content discovered during assessment are redacted.

2. Document Details

Document Title	Vulnerability Assessment & Penetration Testing (VAPT) Report
Component	Python Data Extraction Service
Project (Official ID)	Sales_POD_Invoice_Intelligence_Platform
Project (Human-Readable)	Sales POD Invoice Intelligence Platform
Version	1.0
Date	2026-09-22
Classification	CONFIDENTIAL
Authoring Party	Internal Application Security Assessment (Mediola / Globalspace)
Independent Third-Party Certification	No

3. Document History

Version	Date	Description
1.0	2026-09-22	Initial evidence-based internal VAPT of the Python Data Extraction Service

4. Table of Contents

- 5. Executive / Project Summary
- 6. Assessment Objectives
- 7. Scope
- 8. Out-of-Scope and Not Tested
- 9. Assessment Methodology
- 10. Architecture Overview
- 11. Laravel to Python Data Flow
- 12. Testing Environment
- 13. Tools Used
- 14. Endpoint Inventory
- 15. Security Controls Reviewed
- 16. Security Strengths
- 17. Vulnerability Summary
- 17b. QA Severity Review
- 18. OWASP Top 10 and API Security Top 10
- 19. Detailed Technical Findings
- 20. Evidence Notes
- 21. Remediation Summary
- 22. Dependency / SCA Results
- 23. Network and TLS
- 24. Risk Definitions

- 25. Limitations
- 26. Conclusion
- 27. Disclaimer
- Appendix A. Endpoint table
- Appendix B. Not Tested register

5. Executive / Project Summary

An internal vulnerability assessment and penetration test was performed against the Python Data Extraction Service that supports Sales_POD_Invoice_Intelligence_Platform. The service is a FastAPI application executed by Uvicorn from /var/www/html/split-extract/runner.py. Testing combined source review, configuration review, safe unauthenticated HTTP probes, OpenSSL protocol checks, listener inspection, and a pip-audit scan of the virtual environment that the process uses.

Confirmed, potential, and informational findings total 13. No Critical or High finding is reported. Severity was not raised to meet a target count.

Severity	Count
Critical	0
High	0
Medium	6
Low	4
Informational	3

Figure — Severity distribution (this assessment)

Priority remediation: require authentication and restrict the service to the Laravel callers; remove arbitrary URL fetch; stop publishing port 8001 in cleartext; tighten permissions on the environment file and rotate the credentials stored in it; reload the service only after the intended internal inference endpoint is the one actually running.

Coverage statement: areas marked Not Tested were outside the tests that were executed and are not a statement that those areas are secure.

HTTP evidence labeling: captured HTTP request/response evidence is from curl. It is not a Burp Suite screenshot and not an OWASP ZAP alert.

6. Assessment Objectives

- Identify weaknesses in authentication, authorization, and the Laravel-to-Python trust boundary.
- Assess file upload, PDF, OCR, and temporary-file handling for injection and path abuse.
- Determine which inference provider the running process actually calls.
- Record only findings that source, configuration, or a safe probe supports.

7. Scope

Item	In scope basis
Source tree /var/www/html/split-extract	app.py, services/, runner.py, requirements, unit, Dockerfile
Live process on TCP 8001	PID 1095352, Python 3.12.3, FastAPI 0.115.8, Uvicorn 0.34.0
nginx vhost zydus-py.mediola.in	/extract/ proxied to 127.0.0.1:8001
Environment file /var/www/html/.env	Key names, lengths, and file mode only
Virtualenv dependency set	pip-audit of the interpreter that runs the service

8. Out-of-Scope and Not Tested

Destructive attacks, denial-of-service floods, malware uploads, social engineering, physical security, and extraction of model weights were out of scope. The following checks were not executed:

ID	Item	Reason
NT-01	Off-box Internet port scan	nmap is not installed. Port exposure was assessed from this host.
NT-02	Cloud metadata URL	The SSRF proof used an assessor listener and a closed port. 169.254.169.254 was not requested.
NT-03	Live Azure blob read or overwrite	Credentials and code were reviewed. No customer object was downloaded or modified.
NT-04	Resource-exhaustion load test	Concurrent large uploads were not sent.

ID	Item	Reason
NT-05	Laravel response validation	Laravel source was not present on this host.
NT-06	Burp Suite, OWASP ZAP, Nikto, Nuclei, Semgrep, Bandit, Trivy, testssl.sh	Those tools were not installed and were not run.

9. Assessment Methodology

The approach followed OWASP Testing Guide principles and the OWASP API Security Top 10 as a test checklist: discover the real routes and deployment, review source and configuration, run only non-destructive probes, scan dependencies separately from code findings, and confirm each result before assigning a status. CVSS v3.1 was calculated where the evidence supported a vector. This is not an OWASP certification of the application.

10. Architecture Overview

The running component is a single-worker FastAPI application. nginx terminates TLS for zydus-py.mediola.in and proxies /extract/ to 127.0.0.1:8001. The same process also listens on 0.0.0.0:8001. PDF text is read with PyMuPDF and pdfplumber. Images and weak text fall through to Tesseract. The loaded process then calls Google Vertex AI model gemini-2.5-flash-lite. The source tree on disk, which is newer than the process start, instead posts PDFs to the internal HTTPS endpoint https://zydus-aimodel.mediola.in/v1/invoice/extract. Azure Blob Storage container invoice-splits is used for split-file upload. Temporary uploads use tempfile.mkstemp.

Layer	Verified implementation
Framework	FastAPI 0.115.8, Starlette 0.45.3, Uvicorn 0.34.0, Python 3.12.3
Entry point	runner.py listening on 0.0.0.0:8001 as root, started 2026-09-21 05:15:25
Public URL	https://zydus-py.mediola.in/extract/ -> http://127.0.0.1:8001/
OCR	pdfplumber, PyMuPDF, pytesseract (Tesseract present)
Live inference	Google Vertex AI, model gemini-2.5-flash-lite, project pod-ocr-502015
Source-tree inference	HTTPS client in services/internal_invoice_ai.py (not loaded)
Object storage	Azure Blob, container invoice-splits; account name redacted
Laravel code	Not present on this host

11. Laravel to Python Data Flow

Laravel application source was not on this host, so the HTTP client, timeout, and response checks inside Laravel were not reviewed. The boundary that was verified is the Python side and the nginx vhost.

Observed path: a caller at 135.235.16.138 issued POST /split-and-extract and received HTTP 200. The application log shows a URL download stage, OCR, a Gemini generateContent call, and an Azure blob PUT. Nothing in nginx or FastAPI checks an API key, a client certificate, or the caller address. HTTPS is enforced only for clients that use port 443. Mutual TLS is not configured. An Internet client can call https://zydus-py.mediola.in/extract/ directly and bypass whatever controls exist only inside Laravel. Whether Laravel validates the JSON it receives was Not Tested.

Question	Result
Publicly reachable?	Yes, via https://zydus-py.mediola.in/extract/
Intended as internal-only?	The nginx path is a public vhost. No allow list was configured.
Authentication required?	No
Trusts Laravel only by network origin?	No origin check. Any client that reaches the URL is served.
HTTPS enforced?	On port 443, HTTP redirects to HTTPS. Port 8001 is cleartext.
mTLS?	No
API key?	No
Direct extraction by an external user?	Yes. Unauthenticated requests are processed.
Request limits?	One semaphore on /split-and-extract in source. No edge rate limit. Load test Not Tested.
Laravel response validation?	Not Tested. Laravel source absent.

12. Testing Environment

Primary URL	https://zydus-py.mediola.in/extract/
Direct listener	0.0.0.0:8001
Host address observed	148.230.66.182
Assessment date	2026-09-22
Mode	Read-only configuration review and safe probes. No intentional destructive payloads.

13. Tools Used

Actually used

Tool	Use
curl	HTTP requests and response capture
openssl	Certificate and TLS 1.0/1.1/1.2/1.3 checks
ss, iptables, ufw	Listeners and host firewall
journalctl	Sanitized runtime inference evidence
Manual review	Routes, auth, file handling, SSRF, deserialization patterns
pip-audit 2.10.1	Dependency advisory scan of the running virtualenv
Python 3.12.3	Version and package inspection

Not used: Burp Suite, OWASP ZAP, Nikto, Nuclei, Semgrep, Bandit, Trivy, testssl.sh, nmap. Request and response blocks are curl evidence.

14. Endpoint Inventory

Routes below are those exposed by the live OpenAPI document, plus the framework documentation routes that returned HTTP 200. /split and /extract are not application routes; both returned HTTP 404 on the application port. The public prefix is /extract/ because nginx strips that prefix when proxying.

Method	Endpoint	Authentication	Purpose	Risk
GET	/	None	Service banner and feature list	Information disclosure
GET	/health	None	Readiness and in-flight job fields	Operational data, model name
GET	/live	None	Process liveness	Low
GET	/ready	None	Readiness snapshot	Operational data
GET	/docs	None	Swagger UI	API map
GET	/redoc	None	ReDoc	API map
GET	/openapi.json	None	Machine-readable schema	API map
POST	/split-and-extract	None	Split, OCR, infer, optional blob upload	Auth, SSRF, blob path
POST	/test-extract	None	Direct extract without the main queue	Auth, resource use
POST	/extract-sales-statement	None	Sales or stock statement extract	Auth, upload
POST	/extract-pod-grn	None	GRN workbook extract or URL fetch	Auth, SSRF

Figure — Endpoint inventory from the live service

FastAPI logged a duplicate operation ID for extract_sales_statement_endpoint. The current source decorates POST /extract-sales-statement twice. Live OpenAPI exposes one POST for that path. The first registered handler is the one that runs.

15. Security Controls Reviewed

Control area	Result
Authentication	Absent on every live route (PY-VAPT-001)
Authorization	No user or object model. Blob paths are caller-influenced (PY-VAPT-009, Potential).
File upload	Extension and content-type checks. No demonstrated command injection.

Control area	Result
Path traversal	Uploads go to mkstemp paths. Blob names are cloud keys, not local paths.
Command injection	No os.system, shell=True, eval, or exec in the current Python tree.
SSRF	Confirmed on split_raw_url (PY-VAPT-002).
SQL injection	No SQL client in this service.
Deserialization	No pickle, marshal, jsonpickle, or yaml.load in the service tree.
XXE	No XML parser use found. Dynamic XXE was Not Tested.
Temporary files	mkstemp and NamedTemporaryFile. Cleanup is present on the success and error paths reviewed.
Rate limiting	Partial semaphore only. See PY-VAPT-010.
TLS	Port 443 allows TLS 1.2 and 1.3 only. Port 8001 does not use TLS.
Secrets	World-readable .env (PY-VAPT-006). Google JSON key file is mode 600.

16. Security Strengths

The following controls were verified during this assessment.

ID	Control	Evidence
STR-001	TLS 1.0 and TLS 1.1 did not negotiate on the nginx vhost. TLS 1.2 and TLS 1.3 did.	tls/openssl_protocols.txt
STR-002	Port 80 for zydus-py.mediola.in redirects to HTTPS.	nginx vhost return 301
STR-003	GET /.env on the vhost returns the 35-byte banner, not the secrets file.	evidence/nginx_dotenv.body
STR-004	The Google application-credentials JSON file is mode 600 and root-owned.	process environment path stat
STR-005	Current source rejects a non-HTTPS INVOICE_AI_API_URL before calling the internal model.	services/internal_invoice_ai.py
STR-006	No os.system, shell=True, eval, exec, pickle, or yaml.load in the current service Python files.	source search
STR-007	Upload bodies are written through tempfile.mkstemp rather than a caller-chosen path.	app.py upload handlers
STR-008	/split-and-extract in current source holds a one-slot semaphore before OCR.	MAX_CONCURRENT_REQUESTS=1
STR-009	The Let's Encrypt certificate matches DNS:zydus-py.mediola.in and is inside its validity window.	tls/openssl_protocols.txt

17. Vulnerability Summary

Severity	Count
Critical	0
High	0
Medium	6
Low	4
Informational	3

ID	Vulnerability	Severity	CVSS	Status
PY-VAPT-001	Unauthenticated Public Access to the Extraction API	Medium	6.5	Confirmed
PY-VAPT-002	Server-Side Request Forgery via split_raw_url	Medium	6.5	Confirmed
PY-VAPT-003	Exception Text Returned in API Error Responses	Low	3.7	Confirmed
PY-VAPT-004	CORS Allows Any Origin With Credentials	Low	3.1	Confirmed
PY-VAPT-005	Missing Browser Security Headers and Version Disclosure	Low	3.1	Confirmed
PY-VAPT-006	World-Readable Environment File Holding Cloud and AI Credentials	Medium	5.5	Confirmed
PY-VAPT-007	Extraction API Listens in Cleartext on All Interfaces	Medium	5.3	Confirmed
PY-VAPT-008	Running Process Still Calls Google Vertex Gemini After the Source Tree Moved to an Internal AI Client	Medium	5.3	Confirmed

ID	Vulnerability	Severity	CVSS	Status
PY-VAPT-009	Caller-Supplied Azure Container and Blob Path on an Unauthenticated API	Medium	6.5	Potential
PY-VAPT-010	No Per-Client Rate Limit; Test Route Does Not Use the Global Concurrency Gate	Low	5.3	Potential
PY-VAPT-011	Dependency Advisories Reported by pip-audit (Exploitability Not Demonstrated)	Informational	0.0	Informational
PY-VAPT-012	Extraction Process Runs as Root	Informational	0.0	Informational
PY-VAPT-013	Container Build File Does Not Match the Running Service	Informational	0.0	Informational

Figure — Vulnerability summary (this assessment)

17b. QA Severity Review

Each finding was checked against the evidence before the label was kept. No finding was raised to High. SSRF and missing authentication stayed Medium because metadata, cross-tenant invoice download, and a full reflected document were not part of the proof. Dependency advisories stayed Informational because they were not exploited.

Finding	Evidence supports the label?	Final severity	Final CVSS
PY-VAPT-001	Yes. 400/422 rather than 401, public docs.	Medium	6.5
PY-VAPT-002	Yes for the fetch. Not raised: metadata not requested.	Medium	6.5
PY-VAPT-003	Yes for the error string. Secret text was not in it.	Low	3.7
PY-VAPT-004	Yes. No cookie session, so impact stays Low.	Low	3.1
PY-VAPT-005	Yes. Version banner and missing headers.	Low	3.1
PY-VAPT-006	Yes. Mode 644 and non-empty secrets. Not an HTTP download.	Medium	5.5
PY-VAPT-007	Yes. Cleartext listener answered on the host address.	Medium	5.3
PY-VAPT-008	Yes. Health model name and journal generateContent call.	Medium	5.3
PY-VAPT-009	Code and credentials only. Blob abuse not executed.	Medium	6.5
PY-VAPT-010	Control gap only. Load test not run.	Low	5.3
PY-VAPT-011	Scanner output only.	Informational	0.0
PY-VAPT-012	Root confirmed. No code execution.	Informational	0.0
PY-VAPT-013	File drift only. Container not running.	Informational	0.0

Figure — QA severity review

18. OWASP Top 10 and API Security Top 10

Category	Status	Notes
A01 Broken Access Control	FOUND	PY-VAPT-001, PY-VAPT-009
A02 Cryptographic Failures	FOUND	PY-VAPT-007 cleartext port. TLS 1.2/1.3 on 443 is a strength.
A03 Injection	NOT FOUND	No shell, eval, or SQL use in the current tree. Command injection not shown.
A04 Insecure Design	FOUND	PY-VAPT-010
A05 Security Misconfiguration	FOUND	PY-VAPT-001, 003, 004, 005, 006, 008, 012, 013
A06 Vulnerable Components	FOUND	PY-VAPT-011 informational SCA
A07 Identification and Authentication Failures	FOUND	PY-VAPT-001
A08 Software and Data Integrity Failures	NOT TESTED	Update integrity and CI signing were not assessed.
A09 Security Logging and Monitoring Failures	NOT FOUND	Request and inference events are logged. Log content can include document text; treat logs as sensitive.
A10 SSRF	FOUND	PY-VAPT-002
API2 Broken Authentication	FOUND	PY-VAPT-001
API4 Unrestricted Resource Consumption	POTENTIAL	PY-VAPT-010
API7 SSRF	FOUND	PY-VAPT-002

Category	Status	Notes
API8 Security Misconfiguration	FOUND	Public docs and health

19. Detailed Technical Findings

Each finding uses the same field order: identifier, severity, CVSS, status, CWE, OWASP mapping, affected component, description, impact, root cause, recommendation, reproduction, sanitized request and response, and evidence references.

PY-VAPT-001: Unauthenticated Public Access to the Extraction API

Severity	Medium
CVSS v3.1 Score	6.5
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Status	Confirmed
CWE	CWE-306: Missing Authentication for Critical Function
OWASP	OWASP Top 10 A01 Broken Access Control; A05 Security Misconfiguration; OWASP API Security API2 Broken Authentication
Affected Component	FastAPI application app:app on 127.0.0.1:8001, published by nginx at https://zydus-py.mediola.in/extract/
Affected Endpoint	GET /, /health, /live, /ready, /docs, /redoc, /openapi.json; POST /split-and-extract, /test-extract, /extract-sales-statement, /extract-pod-grn

Description

The running service accepts extraction and documentation requests without an API key, bearer token, mutual TLS, or source-IP allow list. Empty unauthenticated POSTs returned HTTP 400 or HTTP 422 (validation), not HTTP 401 or HTTP 403. Swagger UI, ReDoc, and the OpenAPI document are reachable on the public HTTPS path. A production POST /split-and-extract from 135.235.16.138 completed HTTP 200 during the assessment window; that observation shows the endpoint is in active use, and the same route accepted the assessor's unauthenticated probes.

Business Impact

Unauthorized use of extraction capacity and a direct path around the Laravel application.

Technical Impact

Missing authentication on every assessed route, including interactive API documentation.

CVSS Rationale

Network access without credentials reaches processing and documentation. Confidentiality and integrity are Low because a customer invoice was not submitted by the assessment and cross-tenant data was not downloaded. Availability impact from flooding was not tested, so Availability is None.

Root Cause

Routes are registered on the FastAPI app with no authentication dependency. The reverse proxy forwards Internet clients directly to the application.

Expected Result

HTTP 401 or HTTP 403 for callers without a service credential. Documentation disabled on the public interface.

Actual Result

HTTP 200 for /docs, /health, /openapi.json, and /. HTTP 400 or HTTP 422 for unauthenticated extraction posts.

Impact

Any client who can reach the host can invoke document extraction, read operational health data, and download the API schema. Laravel authorization checks, if any, are not enforced at this service.

Recommendation

Require a shared API key or mTLS between the Laravel application and this service, and reject missing credentials with HTTP 401. Restrict the nginx location to the application servers. Disable /docs, /redoc, and /openapi.json on the public vhost.

Steps to Reproduce

1. Request GET https://zydus-py.mediola.in/extract/docs with no credentials and observe HTTP 200.
2. POST https://zydus-py.mediola.in/extract/split-and-extract with an empty body and no Authorization header.
3. POST http://127.0.0.1:8001/test-extract with an empty body.
4. Compare the status codes with an authentication challenge.

Request (sanitized)

```
POST /split-and-extract HTTP/1.1
Host: 127.0.0.1:8001
(no Authorization header)

POST /test-extract HTTP/1.1
Host: 127.0.0.1:8001
(no Authorization header)

GET /extract/docs HTTP/1.1
Host: zydus-py.mediola.in
```

Response (sanitized)

```
split-and-extract -> HTTP 400
{"detail": "Provide either file upload or split_raw_blob_path/split_raw_url"}

test-extract -> HTTP 422
{"detail": [{"type": "missing", "loc": ["body", "file"], "msg": "Field required"}]}

/extract/docs -> HTTP 200 HTML Swagger UI
```

Evidence

No authentication dependency, middleware, or shared-secret check exists on the FastAPI routes in the current source. Live requests without an Authorization header were processed. OpenAPI lists eight application routes plus the default documentation routes. nginx location /extract/ proxies to 127.0.0.1:8001 with no auth_request or allow/deny rule.

Observed Result

Documentation returned HTTP 200. Empty extraction calls returned HTTP 400 or HTTP 422 with a validation message. Neither response was an authentication failure.

Evidence Files

- evidence/post_split_noauth.headers
- evidence/post_split_noauth.body
- evidence/post_test_noauth.body
- evidence/https_extract_health.body

References

- CWE-306
- OWASP API Security Top 10 API2

PY-VAPT-002: Server-Side Request Forgery via split_raw_url

Severity	Medium
CVSS v3.1 Score	6.5
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Status	Confirmed
CWE	CWE-918: Server-Side Request Forgery
OWASP	OWASP Top 10 A10 SSRF; OWASP API Security API7 Server Side Request Forgery
Affected Component	POST /split-and-extract and POST /extract-pod-grn form field split_raw_url
Affected Endpoint	POST /split-and-extract ; POST /extract-pod-grn ; public path POST /extract/extract-pod-grn

Description

Both routes download split_raw_url with requests.get and no scheme, host, or redirect allow list. An assessor-controlled listener on 127.0.0.1:8765 recorded GET /marker.txt when the field was submitted to the local service and again when the same field was submitted through https://zydus-py.mediola.in/extract/extract-pod-grn. A closed local port on /split-and-extract produced HTTP 500 whose body was the Python HTTP client error, confirming that the running process attempted the connection. Cloud metadata addresses were not requested.

Business Impact

The service can be used as an open fetcher for internal HTTP endpoints that the host can reach.

Technical Impact

Unauthenticated server-side GET with response handling that inspects the downloaded body.

CVSS Rationale

Scope is Unchanged because the demonstration retrieved an assessor file and a connection error, not a separate security domain's secrets. Confidentiality and integrity are Low. Metadata access was Not Tested and is not included in the score.

Root Cause

split_raw_url is passed to requests.get without an allow list. The same pattern is present on /extract-pod-grn.

Expected Result

URL fetch rejected, or limited to a known storage host, and unauthenticated callers rejected.

Actual Result

Listener recorded the GET. The API returned HTTP 400 for the marker file and HTTP 500 with the connection error for the closed port.

Impact

A remote caller can make the server request URLs of their choosing, including loopback addresses reachable from the host. A document the parser accepts would be processed by the extraction pipeline. Metadata and internal credential endpoints were not requested, so that impact is not claimed.

Recommendation

Remove arbitrary URL fetch, or allow only HTTPS URLs on an explicit host list. Do not follow redirects to other hosts. Require authentication before any fetch. Return a generic error instead of the client exception.

Steps to Reproduce

1. Start a listener on 127.0.0.1:8765 serving a non-document marker file.
2. POST /extract-pod-grn with split_raw_url=http://127.0.0.1:8765/marker.txt and use_blob_storage=false, without credentials.
3. Repeat the POST through https://zydus-py.mediola.in/extract/extract-pod-grn.
4. POST /split-and-extract with split_raw_url pointed at a closed local port and record the error body.

Request (sanitized)

```
POST /extract-pod-grn HTTP/1.1
Host: zydu-spy.mediola.in
Content-Type: multipart/form-data

split_raw_url=http://127.0.0.1:8765/marker.txt
use_blob_storage=false
(no Authorization)

POST /split-and-extract HTTP/1.1
Host: 127.0.0.1:8001

split_raw_url=http://127.0.0.1:9/closed.pdf
use_blob_storage=false
```

Response (sanitized)

```
extract-pod-grn -> HTTP 400
{"detail": "Unsupported Excel format: .txt"}
Listener: GET /marker.txt HTTP/1.1 200 (local and via the public HTTPS path)

split-and-extract -> HTTP 500
{"detail": "HTTPConnectionPool(host='127.0.0.1', port=9): ... Connection refused"}
```

Evidence

Listener log shows two successful GET /marker.txt requests from 127.0.0.1. The pod-grn handler then returned HTTP 400 {"detail": "Unsupported Excel format: .txt"}, which shows the downloaded bytes were inspected. The split-and-extract handler returned the connection-refused exception text for http://127.0.0.1:9/closed.pdf.

Observed Result

The service issued outbound HTTP GETs to the supplied URL and returned a response derived from that fetch. No Authorization header was required.

Evidence Files

- evidence/ssrf_listener.log
- evidence/ssrf_pod.body
- evidence/ssrf_https.headers
- evidence/ssrf_split.body

References

- CWE-918
- OWASP API Security API7

PY-VAPT-003: Exception Text Returned in API Error Responses

Severity	Low
CVSS v3.1 Score	3.7
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
Status	Confirmed
CWE	CWE-209: Generation of Error Message Containing Sensitive Information
OWASP	OWASP Top 10 A05 Security Misconfiguration
Affected Component	HTTPException(detail=str(e)) on extraction handlers, confirmed on the running /split-and-extract route
Affected Endpoint	POST /split-and-extract

Description

When the URL download on /split-and-extract fails, the handler returns HTTP 500 and places the exception string in the JSON detail field. The captured body included the internal host, port, and operating-system error. Current source uses the same detail=str(e) pattern on /extract-sales-statement, /extract-pod-grn, /test-extract, and the blob upload helper. The captured body did not contain a credential or customer invoice.

Business Impact

Reconnaissance aid. Customer content was not present in the captured error.

Technical Impact

Internal connection details disclosed to an unauthenticated caller.

CVSS Rationale

Attack complexity is scored High because the confirmed body was a connection error. A score that assumes credential disclosure would overstate the evidence.

Root Cause

Broad exception handlers pass str(e) to HTTPException.

Expected Result

Generic HTTP 500 body with no internal host, port, or library traceback.

Actual Result

HTTP 500 JSON containing the connection-pool exception.

Impact

Callers learn internal failure details. If a later exception includes a storage path, account name, or upstream response, that text would be returned as well. That stronger case was not observed.

Recommendation

Return a stable error code to clients and write the exception only to the server log.

Steps to Reproduce

1. POST /split-and-extract with split_raw_url set to an unopened local port.
2. Read the JSON detail field.

Request (sanitized)

```
POST /split-and-extract HTTP/1.1
Host: 127.0.0.1:8001

split_raw_url=http://127.0.0.1:9/closed.pdf
```

Response (sanitized)

```
HTTP/1.1 500 Internal Server Error
Content-Type: application/json

{"detail": "HTTPConnectionPool(host='127.0.0.1', port=9): Max retries exceeded ... Connection refused"}
```

Evidence

HTTP 500 response body from the closed-port probe. Source review of the exception handlers in app.py.

Observed Result

The client received the Python requests exception text, including 127.0.0.1 and port 9.

Evidence Files

- evidence/ssrf_split.headers
- evidence/ssrf_split.body

References

- CWE-209

PY-VAPT-004: CORS Allows Any Origin With Credentials

Severity	Low
CVSS v3.1 Score	3.1
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Status	Confirmed
CWE	CWE-942: Permissive Cross-domain Policy with Untrusted Domains
OWASP	OWASP Top 10 A05 Security Misconfiguration
Affected Component	CORSMiddleware on the FastAPI app
Affected Endpoint	OPTIONS /health (representative); middleware applies to the application

Description

The application sets allow_origins to ["*"], allow_credentials to True, and allow_methods and allow_headers to ["*"]. A preflight from Origin https://evil.example received access-control-allow-origin: https://evil.example and access-control-allow-credentials: true. The service does not issue a session cookie, so a browser credential-theft scenario was not demonstrated.

Business Impact

Limited today because the API is not cookie-authenticated. The policy is unsafe if session cookies are introduced.

Technical Impact

Arbitrary origin reflection with credentials enabled.

CVSS Rationale

User interaction is required for a browser attack, and cookie authentication was not present, so complexity is High and impact is Low.

Root Cause

Wildcard origin combined with credentialed CORS. Starlette reflects the request origin when credentials are enabled.

Expected Result

Only approved application origins are returned. Credentials are disabled unless required.

Actual Result

access-control-allow-origin echoed the assessor origin and access-control-allow-credentials was true.

Impact

If cookie authentication is added later, any website could make credentialed browser calls. With the current absence of cookie authentication, the demonstrated impact is policy weakness rather than data theft.

Recommendation

Set an explicit origin list for the Laravel application. Do not combine a reflected origin with allow_credentials unless that origin is trusted.

Steps to Reproduce

- 1. Send OPTIONS /health with Origin: https://evil.example and Access-Control-Request-Method: POST.
- 2. Read Access-Control-Allow-Origin and Access-Control-Allow-Credentials.

Request (sanitized)

```
OPTIONS /health HTTP/1.1
Host: 127.0.0.1:8001
Origin: https://evil.example
Access-Control-Request-Method: POST
```

Response (sanitized)

```
HTTP/1.1 200 OK
access-control-allow-origin: https://evil.example
access-control-allow-credentials: true
access-control-allow-methods: DELETE, GET, HEAD, OPTIONS, PATCH, POST, PUT
```

Evidence

Captured preflight response. Source: app.add_middleware(CORSMiddleware, allow_origins=["*"], allow_credentials=True, allow_methods=["*"], allow_headers=["*"]).

Observed Result

The supplied origin was reflected and credentials were allowed.

Evidence Files

- evidence/cors.headers

References

- CWE-942

PY-VAPT-005: Missing Browser Security Headers and Version Disclosure

Severity	Low
CVSS v3.1 Score	3.1
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Status	Confirmed
CWE	CWE-693: Protection Mechanism Failure; CWE-200: Exposure of Sensitive Information
OWASP	OWASP Top 10 A05 Security Misconfiguration
Affected Component	nginx vhost zydus-py.mediola.in and the uvicorn process
Affected Endpoint	GET https://zydus-py.mediola.in/extract/health ; GET http://127.0.0.1:8001/health

Description

The HTTPS response identified Server: nginx/1.24.0 (Ubuntu) and did not send Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options, X-Frame-Options, or Referrer-Policy. The direct application response identified server: uvicorn. Version strings help target known web-server issues. Header absence matters mainly if a browser client is introduced; the current caller observed in logs is a server-side HTTP client.

Business Impact

Easier version targeting. No demonstrated session compromise from the missing headers.

Technical Impact

Server version disclosure and absent hardening headers.

CVSS Rationale

Impact requires a browser context that was not shown, so user interaction is Required and complexity is High. Confidentiality of the version banner is Low.

Root Cause

nginx and uvicorn default headers, with no security-header configuration on the extraction location.

Expected Result

No product version in Server. HSTS present on HTTPS responses.

Actual Result

Server: nginx/1.24.0 (Ubuntu). No HSTS or CSP. Direct port: server: uvicorn.

Impact

Low reconnaissance value. Clickjacking and MIME-sniffing impact depend on a browser user, which was not the observed integration.

Recommendation

Remove version tokens. Add HSTS on the HTTPS vhost and a baseline of X-Content-Type-Options, Referrer-Policy, and a restrictive Content-Security-Policy for the documentation pages.

Steps to Reproduce

- 1. Request GET https://zydus-py.mediola.in/extract/health.
- 2. Record response headers.
- 3. Request GET http://127.0.0.1:8001/health and record the server header.

Request (sanitized)

```
GET /extract/health HTTP/1.1
Host: zydus-py.mediola.in
```

Response (sanitized)

```
HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
Content-Type: application/json
(no Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options, or X-Frame-Options)
```

Evidence

Response headers from the public health URL and from port 8001.

Observed Result

nginx version disclosed. The listed browser hardening headers were absent. unicorn identified itself on port 8001.

Evidence Files

- evidence/https_security.headers
- evidence/https_extract_health.headers

References

- CWE-693
- CWE-200

PY-VAPT-006: World-Readable Environment File Holding Cloud and AI Credentials

Severity	Medium
CVSS v3.1 Score	5.5
CVSS Vector	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Status	Confirmed
CWE	CWE-732: Incorrect Permission Assignment for Critical Resource
OWASP	OWASP Top 10 A05 Security Misconfiguration
Affected Component	/var/www/html/.env loaded by systemd EnvironmentFile for split-extract
Affected Endpoint	Local filesystem. Not served by nginx (GET https://zydus-py.mediola.in/.env returned the plain-text banner, 35 bytes).

Description

The environment file mode is 644 (owner root, group root, world read). Non-empty values are present for the Azure storage connection string, the Azure account key, a Gemini API key, an OpenAI API key, and a Google application-credentials path. The Google JSON key file itself is mode 600 and root-owned. HTTP retrieval of /.env does not return the file. Secret values are not reproduced in this report.

Business Impact

Full cloud and AI credential disclosure to any local account. Not a public HTTP download.

Technical Impact

World read on a secrets file. Attack vector is Local.

CVSS Rationale

Any local user can read the file (PR:L, AV:L). Confidentiality of the key material is High. Integrity and availability were not changed by the permission alone.

Root Cause

The secrets file was created world-readable. The unit runs as root and does not require world read.

Expected Result

Mode 600 or 640. HTTP response remains the banner or HTTP 404, never the file.

Actual Result

Mode 644 root:root. HTTPS GET /.env body length 35, banner text only.

Impact

A local user or a compromised low-privilege process can read cloud storage keys and AI provider keys.

Recommendation

chmod 600 the file, or 640 with a dedicated service group. Move secrets to a secret store. Rotate the keys that have been stored in the world-readable file. Do not treat the nginx 200 banner as a download of the file.

Steps to Reproduce

- 1. stat -c '%a %U:%G' /var/www/html/.env.
- 2. Confirm secret-bearing keys are non-empty by length only.
- 3. GET https://zydus-py.mediola.in/.env and confirm the body is the banner, not the file.

Request (sanitized)

```
Filesystem: stat /var/www/html/.env
HTTP: GET /.env HTTP/1.1
Host: zydus-py.mediola.in
```

Response (sanitized)

```
stat: 644 root:root
HTTP/1.1 200 OK
Content-Length: 35
Body: Zydus Python API Server is running
```

Evidence

stat mode 644. Key names and value lengths were recorded without printing values. nginx body for /.env is the 35-byte service banner.

Observed Result

Mode 644. Credential material is readable by any local account, including www-data. The file is not downloadable through the nginx vhost.

Evidence Files

- evidence/nginx_dotenv.body
- network/ufw.txt

References

- CWE-732

PY-VAPT-007: Extraction API Listens in Cleartext on All Interfaces

Severity	Medium
CVSS v3.1 Score	5.3
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Status	Confirmed
CWE	CWE-319: Cleartext Transmission of Sensitive Information
OWASP	OWASP Top 10 A02 Cryptographic Failures; A05 Security Misconfiguration
Affected Component	runner.py / systemd unit bind 0.0.0.0:8001 ; host firewall INPUT policy ACCEPT ; ufw inactive
Affected Endpoint	http://<host>:8001/ (parallel to https://zydus-py.mediola.in/extract/)

Description

The production process listens on 0.0.0.0:8001. A request to the host public address on port 8001 returned HTTP 200 for /health with server: uvicorn. Host iptables INPUT policy is ACCEPT and ufw is inactive. nginx already publishes the same application over TLS at /extract/. The cleartext listener bypasses that TLS terminator. An off-box Internet scan was not run because nmap was not installed; the port answered on the address configured on this host.

Business Impact

Cleartext path for invoice uploads beside the intended HTTPS front door.

Technical Impact

Sensitive processing API available without TLS on a non-loopback bind.

CVSS Rationale

Confidentiality is Low for data that would be sent to this port. The assessment used a GET and did not transmit a document or a secret over the cleartext port.

Root Cause

runner.py sets HOST 0.0.0.0 and PORT 8001. The unit does not bind localhost. No host firewall restricts the port.

Expected Result

Port 8001 unreachable except from localhost or an allow-listed application server. Clients use HTTPS only.

Actual Result

HTTP 200 from the public address on port 8001. Firewall does not filter it.

Impact

Document uploads and any future API key sent to port 8001 travel without TLS. The nginx body-size limit and security headers also do not apply to this port.

Recommendation

Bind the application to 127.0.0.1 and publish it only through the nginx TLS vhost. If a direct port must exist, restrict it with a firewall to the Laravel servers.

Steps to Reproduce

- 1. Confirm the listen address with ss.
- 2. Request GET http://<public-address>:8001/health.
- 3. Compare with the TLS path on port 443.

Request (sanitized)

GET /health HTTP/1.1 Host: 148.230.66.182:8001

Response (sanitized)

```
HTTP/1.1 200 OK
server: uvicorn
content-type: application/json
```

Evidence

ss shows 0.0.0.0:8001. curl to http://148.230.66.182:8001/health returned HTTP 200. The access log recorded that source address.

Observed Result

Cleartext HTTP on port 8001 returned the same health document as the TLS path. No TLS is negotiated on 8001.

Evidence Files

- network/listeners.txt
- network/iptables.txt
- network/ufw.txt

References

- CWE-319

PY-VAPT-008: Running Process Still Calls Google Vertex Gemini After the Source Tree Moved to an Internal AI Client

Severity	Medium
CVSS v3.1 Score	5.3
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Status	Confirmed
CWE	CWE-693: Protection Mechanism Failure
OWASP	OWASP Top 10 A05 Security Misconfiguration
Affected Component	Live PID 1095352 (started 2026-09-21 05:15:25) versus app.py and services/internal_invoice_ai.py on disk (modified 2026-09-22)
Affected Endpoint	POST /split-and-extract as executed by the running process; GET /health current_model

Description

GET /health on the running process reports current_model gemini-2.5-flash-lite. A journal excerpt from an existing client request shows google_genai and an HTTP 200 POST to aiplatform.googleapis.com for the model gemini-2.5-flash-lite. The same log prints the loaded pipeline as PDFPlumber, PyMuPDF, Tesseract, then Gemini. The source tree now names the model internal_invoice_ai and sends extraction to the HTTPS URL https://zydus-aimodel.mediola.in/v1/invoice/extract, with an optional bearer token. That URL is not present in the running process environment. The process was not restarted after the source change. The assessment did not submit a document to the model; the outbound call was already in the journal.

Business Impact

Production does not match the current extraction design. Document text continues to leave the host for the Gemini endpoint observed in the journal.

Technical Impact

Stale process. External inference is the live behavior. The on-disk client is a different control and is not loaded.

CVSS Rationale

Confidentiality is Low relative to the external provider call observed in logs. The assessment did not create that request. Integrity and availability were not scored.

Root Cause

The long-running root process imported the previous application and has not been reloaded. dotenv in the working directory does not see /var/www/html/.env unless systemd injected it at start.

Expected Result

Running /health model name matches the deployed source. Outbound inference goes only to the configured internal HTTPS endpoint.

Actual Result

Live health model is gemini-2.5-flash-lite. Disk source names internal_invoice_ai. Journal shows HTTP 200 to the Gemini generateContent URL.

Impact

Invoice content processed by the running service is sent to Google Vertex AI. The source change that points inference at the internal endpoint is not what production is executing. Restarting onto the new code without a token would then call the internal endpoint with no bearer credential, because INVOICE_AI_API_TOKEN is not set in the environment file.

Recommendation

Restart only after the intended provider, token, and HTTPS URL are confirmed in the process environment. Verify /health reports internal_invoice_ai and that no generateContent calls remain. Keep provider credentials out of the world-readable environment file.

Steps to Reproduce

- 1. GET /health and record current_model.
- 2. Compare that value with get_current_model_config() in the current app.py.
- 3. Compare process start time with app.py modification time.
- 4. Review the sanitized journal line for the generateContent URL.

Request (sanitized)

```
GET /health HTTP/1.1
Host: zydus-py.mediola.in

(no document uploaded by the assessment)
```

Response (sanitized)

```
HTTP/1.1 200 OK
{"status":"healthy","current_model":"gemini-2.5-flash-lite", ... "source_filename":null,"batch_id":null}

Journal (sanitized): POST https://aiplatform.googleapis.com/v1beta1/projects/pod-ocr-502015/locations/global/publishers/
```

Evidence

Health JSON field current_model. Sanitized journal excerpt. Process start time versus file modification time. Disk function extract_full_data_from_text_gemini delegates to the internal client. Disk invoice_ai_api_url() rejects non-HTTPS URLs.

Observed Result

Live model name is gemini-2.5-flash-lite. Disk model name is internal_invoice_ai. The journal shows a successful call to Google Vertex AI.

Evidence Files

- evidence/https_extract_health.body
- evidence/runtime_gemini_egress_redacted.txt

References

- CWE-693
- OWASP A05

PY-VAPT-009: Caller-Supplied Azure Container and Blob Path on an Unauthenticated API

Severity	Medium
CVSS v3.1 Score	6.5
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Status	Potential
CWE	CWE-284: Improper Access Control
OWASP	OWASP Top 10 A01 Broken Access Control; OWASP API Security API1
Affected Component	blob_container, split_raw_blob_path, and target_invoices_blob_folder on /split-and-extract and /extract-pod-grn
Affected Endpoint	POST /split-and-extract ; POST /extract-pod-grn

Description

Current source uses the caller-supplied container and blob path with the process Azure credential, and upload_split_pdf_to_blob can return a read SAS URL. The running process environment has a non-empty Azure connection string and account key. A production request in the journal performed a blob PUT and received HTTP 201, so blob upload is live. The assessment did not download or overwrite a customer blob. Status is Potential for attacker-controlled container access because that action was not executed.

Business Impact

Possible read or write of invoice objects in the storage account if the reviewed code path is reachable. Not demonstrated against live blobs.

Technical Impact

Missing authorization on storage parameters combined with a loaded storage credential.

CVSS Rationale

Scored as Low confidentiality and Low integrity because the code path is present and credentials are loaded, while a live cross-object read was intentionally not executed. Do not treat this as a confirmed data breach.

Root Cause

Storage paths and container names are taken from the request and used with the service credential.

Expected Result

Client container and blob path rejected. No SAS issued to anonymous callers.

Actual Result

Not executed against Azure. Production logging shows the service itself can PUT an object and receive HTTP 201.

Impact

If the loaded code matches the reviewed source, an unauthenticated caller could read a named blob and write extracted output into a chosen prefix, then receive a read URL. That outcome was not demonstrated.

Recommendation

Ignore client container names. Authorize blob operations with a fixed container and a server-side prefix. Do not return account-key SAS URLs to unauthenticated clients. Prefer a user-delegation SAS with a short lifetime after authentication is added.

Steps to Reproduce

- 1. Review the form fields blob_container and split_raw_blob_path.
- 2. Confirm Azure credential variables are non-empty in the process environment without printing them.
- 3. Do not issue a blob read against production data.

Request (sanitized)

Not sent. A live blob read was intentionally not performed.

Response (sanitized)

Not captured. Journal, sanitized: PUT https://[REDACTED].blob.core.windows.net/invoice-splits/[REDACTED] -> HTTP 201.

Evidence

Source of get_blob_service_client, the download branch, and SAS generation. Credential lengths only. Sanitized journal PUT 201. No assessor blob API call.

Observed Result

Code path and live credentials are present. A production upload was observed. An assessor-controlled blob read or container change was not performed.

Evidence Files

- evidence/runtime_gemini_egress_redacted.txt
- source_review/blob_path_review.txt

References

- CWE-284
- OWASP API1

PY-VAPT-010: No Per-Client Rate Limit; Test Route Does Not Use the Global Concurrency Gate

Severity	Low
CVSS v3.1 Score	5.3
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L
Status	Potential
CWE	CWE-770: Allocation of Resources Without Limits or Throttling
OWASP	OWASP Top 10 A04 Insecure Design; OWASP API Security API4 Unrestricted Resource Consumption
Affected Component	/test-extract compared with the semaphore on /split-and-extract; nginx client_max_body_size 500M
Affected Endpoint	POST /test-extract ; POST /split-and-extract ; POST /extract-sales-statement

Description

Current source limits /split-and-extract with a semaphore of MAX_CONCURRENT_REQUESTS=1 and a queue timeout of 3600 seconds. /test-extract does not acquire that semaphore. /extract-sales-statement and /extract-pod-grn also process uploads outside that gate. nginx allows a 500 MB body on the public vhost. A sustained load test was not performed. Status is Potential for availability impact. The missing gate in source, the public route, and the body-size setting are confirmed by inspection.

Business Impact

Processing capacity can be consumed. Not measured.

Technical Impact

Uneven concurrency control and a large proxy body limit, without a demonstrated outage.

CVSS Rationale

Availability is Low and was not proven with a load test, which is why the status is Potential and the severity remains Low even though the base score is 5.3.

Root Cause

Concurrency control was added only around the primary route. No edge rate limit exists.

Expected Result

Every extraction route shares an authenticated limit. Oversized bodies are rejected before OCR.

Actual Result

Control gap confirmed by review. No availability failure was caused or observed.

Impact

A small number of concurrent extraction calls can occupy CPU and memory. The single-flight gate on the main route does not cover every upload route in the current source.

Recommendation

Apply one authenticated, size-capped queue to every extraction route. Remove or firewall /test-extract. Set a smaller nginx body limit that matches the application limit.

Steps to Reproduce

- 1. Compare test_extract with split_and_extract_invoices for semaphore acquisition.
- 2. Read client_max_body_size in the nginx vhost.
- 3. Do not launch a concurrent upload test.

Request (sanitized)

Not sent as a load test.

Response (sanitized)

Not captured. OpenAPI shows POST /test-extract is present.

Evidence

Source comparison of the two handlers. Live OpenAPI exposes /test-extract. nginx client_max_body_size 500M. Environment MAX_CONCURRENT_REQUESTS=1. No load test.

Observed Result

The test route is public and, in the current source, is outside the single-flight gate. Exhaustion was not measured.

Evidence Files

- source_review/concurrency_review.txt

References

- CWE-770
- OWASP API4

PY-VAPT-011: Dependency Advisories Reported by pip-audit (Exploitability Not Demonstrated)

Severity	Informational
CVSS v3.1 Score	0.0
CVSS Vector	Not scored as an application CVSS. Advisory identifiers are those returned by pip-audit 2.10.1.
Status	Informational
CWE	CWE-1104: Use of Unmaintained Third Party Components
OWASP	OWASP Top 10 A06 Vulnerable and Outdated Components
Affected Component	Python virtual environment /var/www/html/venv used by the running service
Affected Endpoint	Not mapped to a single route. Packages are loaded by the service.

Description

pip-audit 2.10.1 reported 83 advisory records. After removing duplicate records, 44 identifiers remain across 10 packages. The assessment did not exploit any advisory. This item is software composition analysis, not a source-code vulnerability. Notable installed versions and the fix versions reported by the tool: pillow 11.1.0 (17 identifiers, fix versions include 12.1.1); starlette 0.45.3 (7, fixes include 0.49.1 and 1.0.1); python-multipart 0.0.20 (6, fixes include 0.0.22); cryptography 48.0.0 (4, fixes include 48.0.1); anyio 4.13.0 (CVE-2026-63374, CVE-2026-64847, fix 4.14.2); pdfminer-six 20231228 (2); pip 26.1.1 (2); requests 2.32.3 (2, fixes include 2.33.0); PyPDF2 3.0.1 (1, fix 3.9.0); python-dotenv 1.0.1 (1, fix 1.2.2). Full identifiers are in

dependencies/pip_audit_unique.json.

Business Impact

Patch planning input. Not a demonstrated breach.

Technical Impact

Known vulnerable versions present. Exploitation not shown.

CVSS Rationale

Aggregate score is 0.0 because individual advisory scores were not revalidated and no exploit was run.

Root Cause

Pinned transitive and direct packages are below the fix versions reported by pip-audit.

Expected Result

pip-audit reports no advisories for the production environment, or each remaining item is accepted with a reason.

Actual Result

44 unique identifiers across 10 packages. No exploit output.

Impact

Unknown until each advisory is triaged against the code paths this service actually uses. Pillow, python-multipart, and the PDF libraries are in the upload path and should be patched first.

Recommendation

Upgrade the listed packages in a test environment, rerun pip-audit, and retest invoice extraction. Prioritize pillow, python-multipart, starlette, and the PDF libraries.

Steps to Reproduce

- 1. Freeze or scan the virtual environment that runner.py uses.
- 2. Deduplicate advisory identifiers.
- 3. Do not treat the scanner count as a count of confirmed application vulnerabilities.

Request (sanitized)

```
Tool invocation: pip-audit --path <venv site-packages>
```

Response (sanitized)

```
See dependencies/pip_audit.json and dependencies/pip_audit_unique.json. No exploit response was generated.
```

Evidence

pip-audit JSON against the running virtual environment. No advisory was turned into an exploit.

Observed Result

The scanner reported the packages and identifiers above. Runtime exploitability was not shown.

Evidence Files

- dependencies/pip_audit.json
- dependencies/pip_audit_unique.json
- dependencies/venv_freeze.txt

References

- OWASP A06

PY-VAPT-012: Extraction Process Runs as Root

Severity	Informational
CVSS v3.1 Score	0.0
CVSS Vector	Not scored. No code-execution primitive was demonstrated.
Status	Informational
CWE	CWE-250: Execution with Unnecessary Privileges
OWASP	OWASP Top 10 A05 Security Misconfiguration
Affected Component	systemd unit split-extract and live PID 1095352
Affected Endpoint	Process credential, not a single route

Description

The unit sets User=root and Group=root. The live process uid is 0. No command injection, deserialization, or template execution issue was confirmed that would turn this into code execution. The privilege level matters if a parser vulnerability is later exploited.

Business Impact

Blast-radius note. Not a standalone exploit.

Technical Impact

Unnecessary privilege on the network-facing parser process.

CVSS Rationale

No CVSS. Impact was not demonstrated.

Root Cause

The unit was written to run as root.

Expected Result

Non-root service account.

Actual Result

Uid 0 confirmed. No root-only action was abused.

Impact

A future memory-corruption or command-injection bug in PDF, image, or OCR code would run as root.

Recommendation

Run the service as a dedicated unprivileged user with write access only to its temp and log directories.

Steps to Reproduce

- 1. Read the unit User= setting.
- 2. Confirm the live process uid.

Request (sanitized)

Not an HTTP request. Process inspection only.

Response (sanitized)

Uid: 0. Unit User=root.

Evidence

/proc uid line and the unit file User=root.

Observed Result

The service runs as root. Code execution was not shown.

Evidence Files

- source_review/process_privileges.txt

References

- CWE-250

PY-VAPT-013: Container Build File Does Not Match the Running Service

Severity	Informational
CVSS v3.1 Score	0.0
CVSS Vector	Not scored. The container is not the running deployment.
Status	Informational
CWE	CWE-1059: Insufficient Technical Documentation
OWASP	OWASP Top 10 A05 Security Misconfiguration
Affected Component	Dockerfile and docker-compose.yml in /var/www/html/split-extract
Affected Endpoint	Not applicable to the live listener. Production entry point is runner.py under systemd.

Description

The Dockerfile copies app5.py, which is not in the tree, installs dependencies as root, and listens on 0.0.0.0:8001. docker-compose publishes port 8001. Docker was not running this service. The live process is the virtualenv interpreter executing runner.py. Building the image as written would fail or run a different file than production.

Business Impact

Risk of deploying the wrong artifact. The live host is not running this image.

Technical Impact

Build definition drift.

CVSS Rationale

No CVSS. The image is not in production on this host.

Root Cause

The image definition was not updated when the entry point became runner.py.

Expected Result

Image entry point matches the systemd service.

Actual Result

COPY app5.py is present. The file is absent. Live command is runner.py.

Impact

An operator who deploys the compose file would not reproduce the service that was tested. This is a deployment-integrity note, not a live exposure.

Recommendation

Point the image at runner.py or app:app, run as a non-root user, and do not publish port 8001 if nginx is the only front door.

Steps to Reproduce

1. Read the Dockerfile CMD and COPY lines.
2. Confirm app5.py is absent.
3. Confirm the live process command line.

Request (sanitized)

Not an HTTP request.

Response (sanitized)

Dockerfile reviewed. Container runtime not in use for this service.

Evidence

Dockerfile COPY app5.py. No app5.py in the project. No running container was found.

Observed Result

The image definition and the running process are different artifacts.

Evidence Files

- source_review/container_review.txt

References

- CWE-1059

20. Evidence Notes

Screenshots of a proxy GUI were not created. Burp Suite and OWASP ZAP were not used. HTTP transcripts are stored as text under python_vapt/evidence/. The journal excerpt was rewritten so that customer names, addresses, invoice identifiers, and blob object keys are not retained. Secret values from the environment file were not copied into the evidence set; only key names and whether the values are non-empty were used.

21. Remediation Summary

Priority	Action	Findings
1	Authenticate the API and allow only the Laravel hosts. Disable public docs.	PY-VAPT-001
1	Delete or strictly allow-list split_raw_url. Return generic errors.	PY-VAPT-002, PY-VAPT-003
1	Bind port 8001 to localhost and keep TLS at nginx.	PY-VAPT-007
1	chmod 600 the environment file and rotate exposed keys.	PY-VAPT-006
2	Restart onto the intended internal HTTPS model only after the token and URL are in the process environment. Confirm /health.	PY-VAPT-008
2	Stop taking container and blob paths from the client.	PY-VAPT-009
3	One size-capped queue for every upload route. Remove /test-extract from production.	PY-VAPT-010
3	Restrict CORS. Add HSTS and drop server versions. Run as a non-root user.	PY-VAPT-004, 005, 012
3	Patch the pip-audit packages, starting with pillow, python-multipart, and starlette.	PY-VAPT-011
3	Align the Dockerfile with runner.py or remove the unused compose path.	PY-VAPT-013

22. Dependency / SCA Results

Software composition analysis is recorded only in PY-VAPT-011. Those identifiers are advisory records from pip-audit. They are not confirmed exploitable vulnerabilities in this service, and they are not counted as source-code findings.

Package	Installed	Unique IDs	Example fix reported by the tool
pillow	11.1.0	17	12.1.1
starlette	0.45.3	7	0.49.1 / 1.0.1
python-multipart	0.0.20	6	0.0.22
cryptography	48.0.0	4	48.0.1
anyio	4.13.0	2	4.14.2
pdfminer-six	20231228	2	20251230
pip	26.1.1	2	26.1.2
requests	2.32.3	2	2.33.0
PyPDF2	3.0.1	1	3.9.0

Package	Installed	Unique IDs	Example fix reported by the tool
python-dotenv	1.0.1	1	1.2.2

23. Network and TLS

Listeners relevant to this service: TCP 8001 (this API, all IPv4 interfaces), TCP 443 and TCP 80 (nginx), TCP 22 (ssh). TCP 8000 is a different local Python process and was not the subject of the extraction tests beyond noting that nginx proxies /pdf/ to it. MySQL and Redis were not listening on this host. nmap from an external vantage point was Not Tested.

Certificate: subject CN=zydus-py.mediola.in, issuer Let's Encrypt YE1, notBefore 2026-09-17, notAfter 2026-12-16, SAN DNS:zydus-py.mediola.in. TLS 1.2 cipher observed: ECDHE-ECDSA-AES256-GCM-SHA384. TLS 1.3 cipher observed: TLS_AES_256_GCM_SHA384. TLS 1.0 and TLS 1.1 did not negotiate. nginx ssl_protocols is TLSv1.2 TLSv1.3. HSTS was not set (PY-VAPT-005).

24. Risk Definitions

Severity	Meaning in this report
Critical	Unproven. None assigned.
High	Unproven. None assigned.
Medium	Confirmed or strongly supported weakness with limited demonstrated data exposure.
Low	Confirmed weakness whose captured impact is reconnaissance or hardening.
Informational	True observation that is not, by itself, an exploited vulnerability.

Status values: Confirmed means the behavior was observed or the configuration was directly inspected. Potential means the code or credential is present and the abusive action was not executed. Informational means the item is recorded without a vulnerability score. False Positive was not required. Not Tested items are listed in section 8 and are not findings.

25. Limitations

The assessment results are based on the source code, configuration, access, tools, and environment available during the assessment period. Areas identified as Not Tested or outside the defined scope have not been independently validated.

The running process started on 2026-09-21. app.py and the internal AI client were modified on 2026-09-22. Dynamic results describe the loaded process. Source-only statements are identified as such. Laravel code, an external port scan, metadata SSRF, blob abuse, and load testing were not performed. Customer invoice text that appeared in the journal was removed from the stored evidence and is not repeated here.

26. Conclusion

The Python Data Extraction Service is reachable on the Internet without authentication, will fetch a caller-supplied URL, and the process that is actually running sends document work to Google Vertex AI Gemini 2.5 Flash Lite. The newer source tree points at an internal HTTPS model API, but that code is not the code in memory. Credentials for cloud storage and AI providers sit in a world-readable environment file. TLS on the nginx vhost is in good condition, and the dangerous code-execution patterns searched for in the current tree were not present. Remediation should start with authentication, network binding, URL-fetch removal, secret permissions and rotation, and a controlled reload onto the intended inference endpoint.

27. Disclaimer

This assessment was conducted internally as a security assessment of the Python Data Extraction Service supporting the Sales POD Invoice Intelligence Platform. The assessment is intended to identify security vulnerabilities and configuration weaknesses within the defined scope and should not be interpreted as a formal certification or independent third-party security certification.

The assessment results are based on the source code, configuration, access, tools, and environment available during the assessment period. Areas identified as Not Tested or outside the defined scope have not been independently validated.

OWASP is cited as the testing methodology and as the Top 10 and API Security Top 10 mapping. OWASP did not certify this application. This report is not an OWASP-certified VAPT.

Appendix A. Live OpenAPI Paths

GET /, GET /health, GET /live, GET /ready, GET /docs, GET /redoc, GET /openapi.json, POST /split-and-extract, POST /test-extract, POST /extract-sales-statement, POST /extract-pod-grn. Application title from OpenAPI: Invoice Splitter + Extractor API v10.0 (PDFPlumber + Tesseract). Schema version 0.1.0.

Appendix B. Not Tested Register

ID	Check	Reason
NT-01	Off-box Internet port scan	nmap is not installed. Port exposure was assessed from this host.
NT-02	Cloud metadata URL	The SSRF proof used an assessor listener and a closed port. 169.254.169.254 was not requested.
NT-03	Live Azure blob read or overwrite	Credentials and code were reviewed. No customer object was downloaded or modified.
NT-04	Resource-exhaustion load test	Concurrent large uploads were not sent.
NT-05	Laravel response validation	Laravel source was not present on this host.
NT-06	Burp Suite, OWASP ZAP, Nikto, Nuclei, Semgrep, Bandit, Trivy, testssl.sh	Those tools were not installed and were not run.

Appendix C. AI Provider Statement

The running process calls Google Vertex AI. Evidence is the health field current_model=gemini-2.5-flash-lite and the journal POST to aiplatform.googleapis.com for publishers/google/models/gemini-2.5-flash-lite:generateContent. The project id in that URL is pod-ocr-502015. The on-disk client, which is not loaded, targets https://zydus-aimodel.mediola.in/v1/invoice/extract over HTTPS and does not call Gemini or OpenAI. No other hosted model was assumed.